Access-drift

Azure 기반 오프보딩 리스크 탐지 보안 솔루션



Team 5 | Access Drift E2E Security

Index

목차

01 팀 소개 · 수행 계획

02 Why · 프로젝트 개요

03 What · 서비스 소개

04 How · 시스템 아키텍처

05 Data Engineering

06 Data Science · AI

07 자체 평가 · 고도화 방안

01

팀 소개 · 수행 계획

팀 구성

이름	역할	주요 담당
주재륜 팀장	DE	프로젝트 리드 · 아키텍처 설계 · DE 파이프라인 설계 및 구현
남기훈	DE	Bronze/Silver 데이터 품질검증·SQL dashboard 구현
원신영	PO	MVP 요구사항 정의·대시보드 UI/UX 설계·Streamlit 구현·영상 기획
정해원	DS	탐지 로직 정리 · Gold/Risk Card 데이터 구조화 ·RAG 연동 원칙 정리
김다영	DS	DS 데이터 계약·Eval 검증 구조·Gold/Risk Card·RAG 연동 설계 정리

수행 계획 & 협업 툴

PHASE 1
기획



- 문제 정의
- MVP 범위 설정
- 데모 시나리오 수립

PHASE 2
설계



- 아키텍처 설계
- 데이터 모델 정의
- Risk Card 설계

PHASE 3
개발



- Databricks Pipeline 구축
- 탐지 로직 구현
- Dashboard 개발

PHASE 4
검증



- End to End 검증
- Gold 결과 확인
- 발표 데모 준비

협업 툴	GitHub	Notion	Databricks
	코드/PR 관리	기획 문서/회의록 정리	개발/검증

02

프로젝트 개요

01 Access Drift 개념

- **사용자의 실제 직무/재직 상태와 시스템상 부여된 접근 권한 사이의 불일치 현상**

HR 이벤트	Drift 발생	실제 권한
퇴사	**회수 누락**	권한 Active
부서 이동	**권한 방치**	이전 부서 권한 누적
계약 종료	**접근 경로 잔존**	Workspace 유지

✓ **발생 요인**

- **멀티 클라우드**와 **SaaS 협업 툴 확산**으로 **권한 관리 지점이 분산됨**
- **AI Agent · AX 전환**으로 NHI와 잔존 접근 경로가 증가하며 **권한 회수 누락 가능성**이 **높아짐**


MBC
coupang
MBC 뉴스25
정치
민주당 "패트 1심' 면죄부 아냐‥나경원, 항소하길"

02 타겟 및 확장 전략

타겟 모델

① 기업 유형

대형 이커머스 플랫폼

② 인프라 환경

Azure + 외부 SaaS 기반의 분산 인프라 환경



③ 보안 현황

분산된 SaaS 권한 및 NHI로 인해 **통합 권한 관리에 사각지대 발생**

비즈니스 확장 전략

① 민감자산 정의 도출

구분	정의
Critical	**법률에 의한 보호 의무**가 명시된 자산
High	비즈니스 생존에 직결되는 **핵심 독점 자산**
Medium	일정 부분 관리 리스크가 발생하는 **내부 자산**

② 확장 타겟

업종	자산 예시
반도체·제조	핵심 기술 도면, 공정 레시피, 설비 운영 데이터
금융	신용 정보, 거래 내역, 계좌·인증 정보

03

서비스 소개

01 제품 목표

GOAL 01

보안 사각지대 Zero

HR 이벤트 이후 남은 접근 경로 식별



GOAL 02

의사결정 리드타임 단축

민감 자산 기준으로 검토 우선순위 제시



GOAL 03

보안 워크플로우 및 감사 대응

권장 조치·티켓 발급으로 대응 흐름 연결



02 서비스 흐름

End-to-End 보안 대응 흐름

01
이상 권한 식별
잔존 권한 탐지
위험도 분류

02
리스크 분석
접근 경로
민감 자산
위험 요인 분석

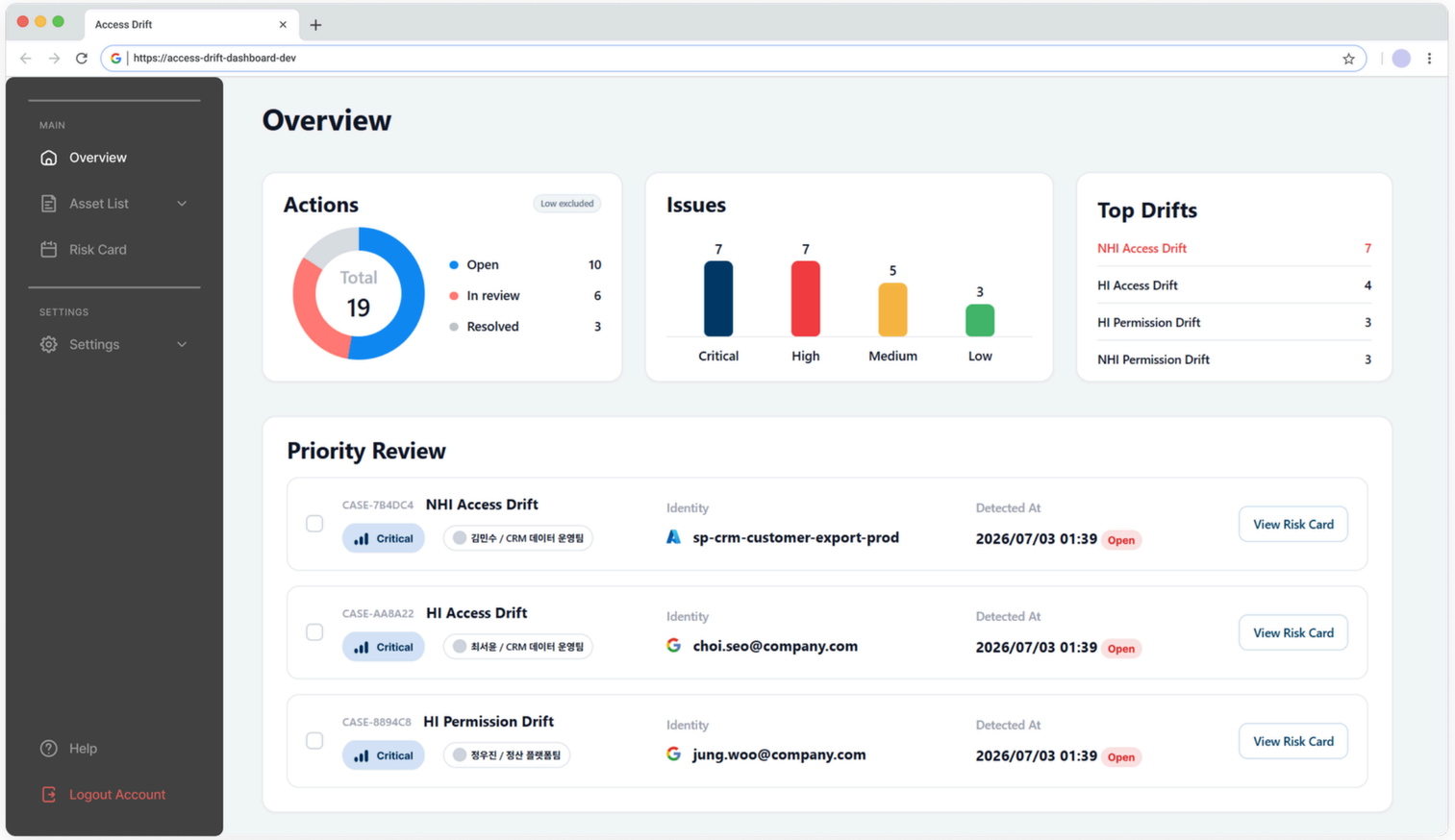
03
조치안 생성
내부 정책, 보안 기준
권장 조치 방향 제시

04
대응 연결
Jira 티켓 전환
담당 부서 조치 연계

05
감사 이력 관리
상태 변경
조치 결과
처리 사유 기록 및 보존

✓ **탐지 결과**를 **리스크 판단, 조치 실행, 감사 대응까지 연결**하는 **통합 보안 대응 솔루션**

02 상세 화면 _Overview



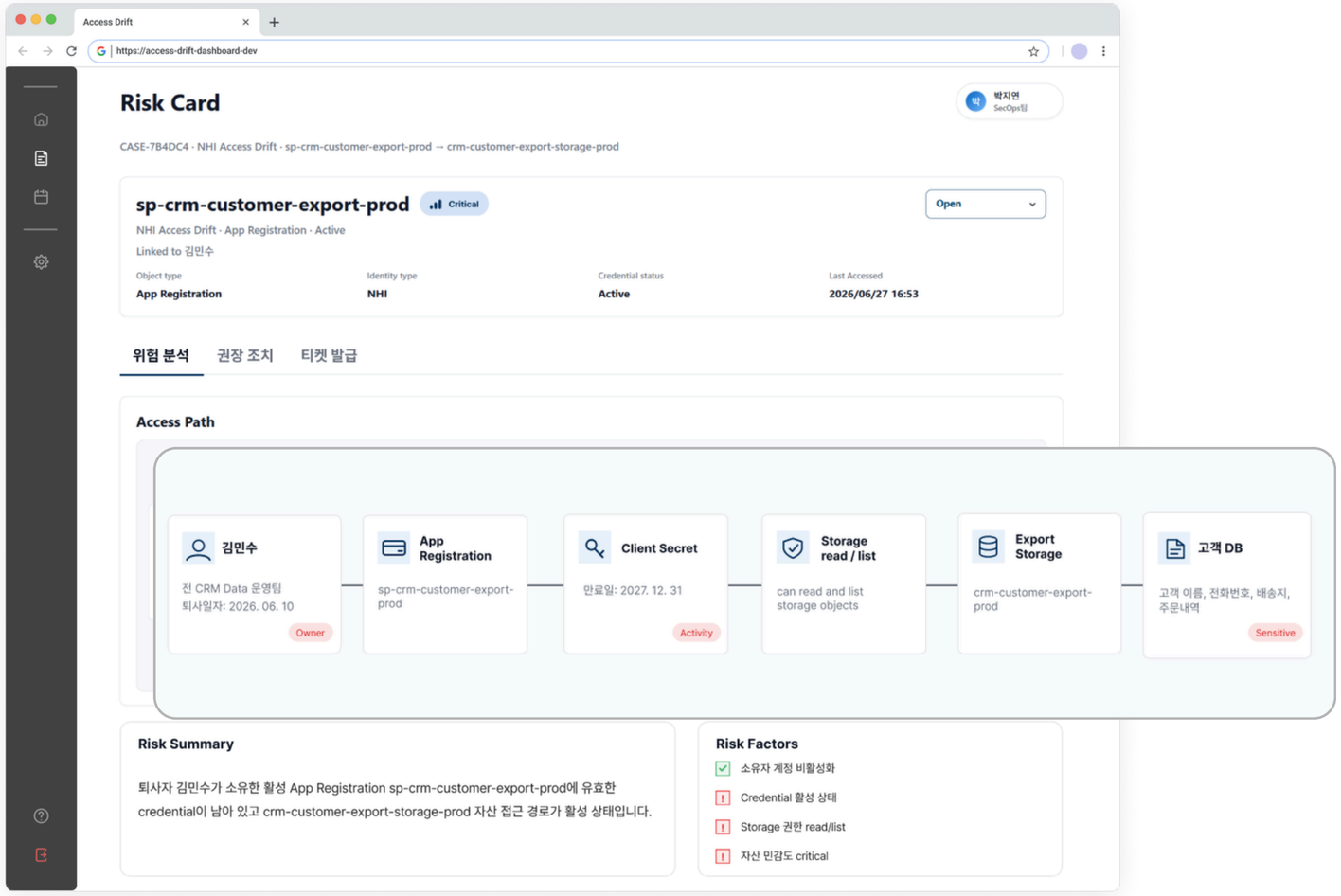
A **Actions**
처리 현황에 대한 요약

B **Issues**
위험도별 분포

C **Top Drifts**
탐지 유형

D **Priority Review**
위험도 기준 Top 3

03 상세 화면 _위험 분석

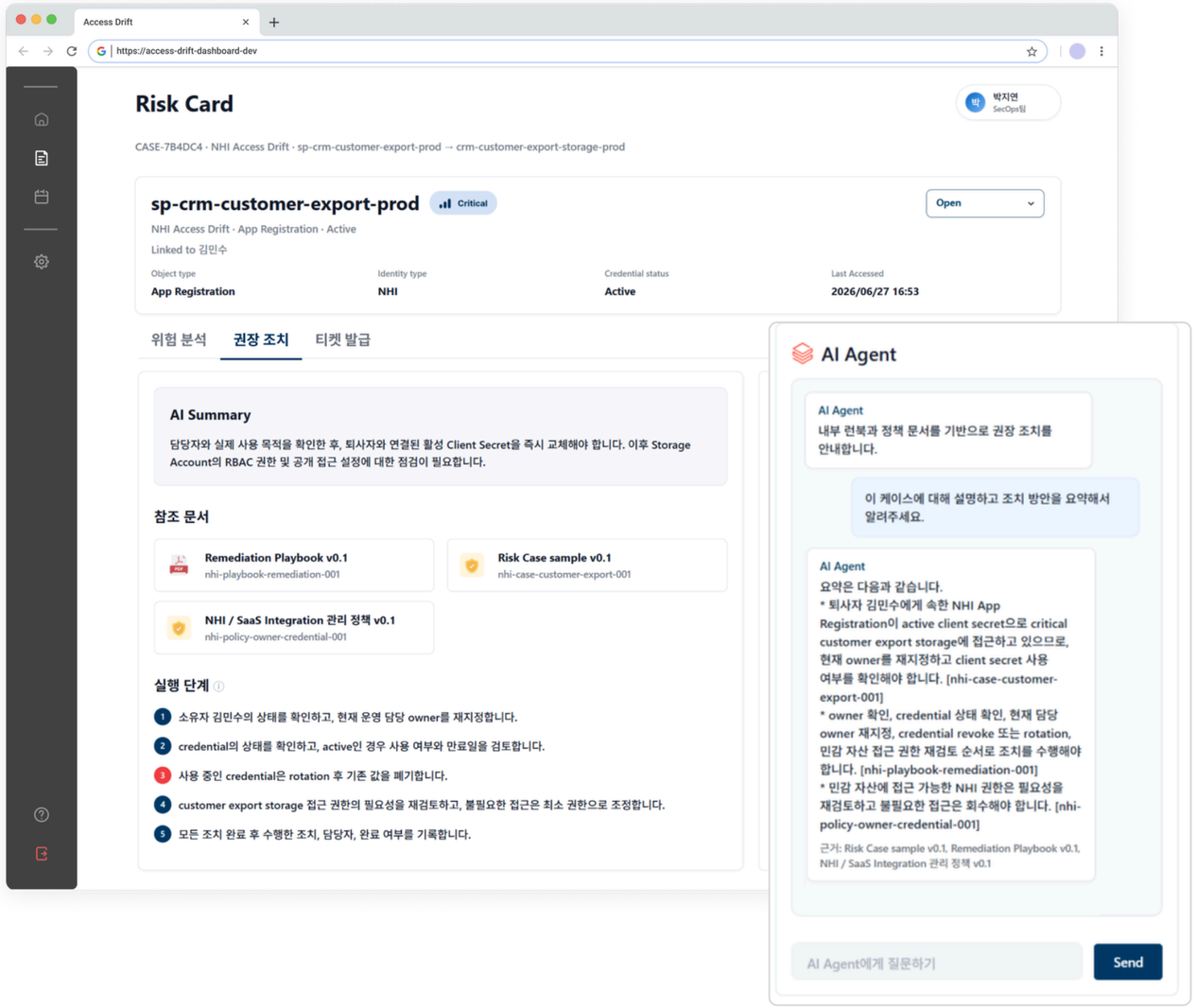


A **Access Path**
권한이 어떤 경로로 자산에 닿는지

B **Risk Summary**
왜 위험한지에 대한 요약

C **Risk Factors**
위험도 판단의 근거 요소

03 상세 화면 _권장 조치



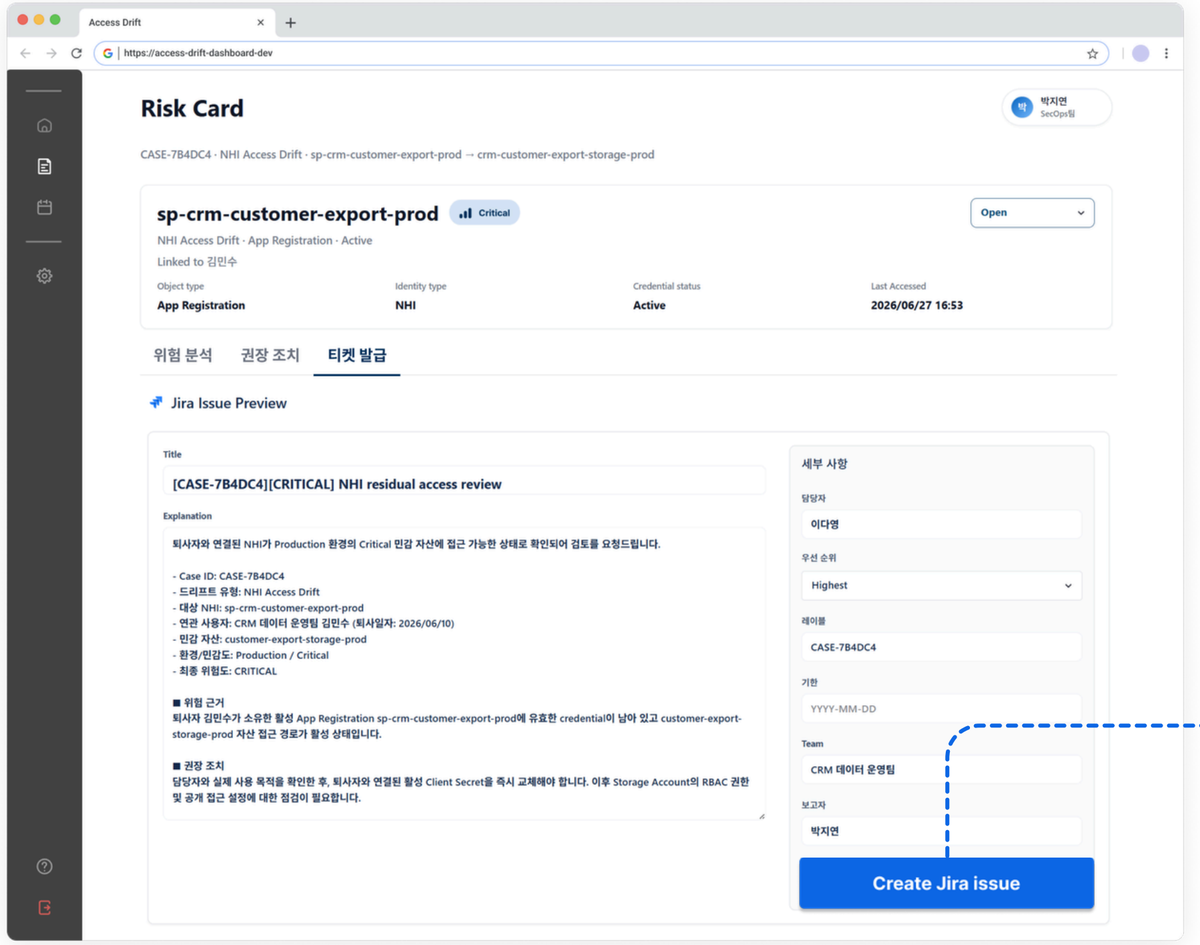
A **AI Summary**
권장 조치 요약

B **참조 문서**
내부 정책 문서 기반의 조치안

C **실행 단계**
단계별 조치 절차 제시

D **AI Agent**
RAG 기반 질의응답 지원

03 상세 화면 _티켓 발급

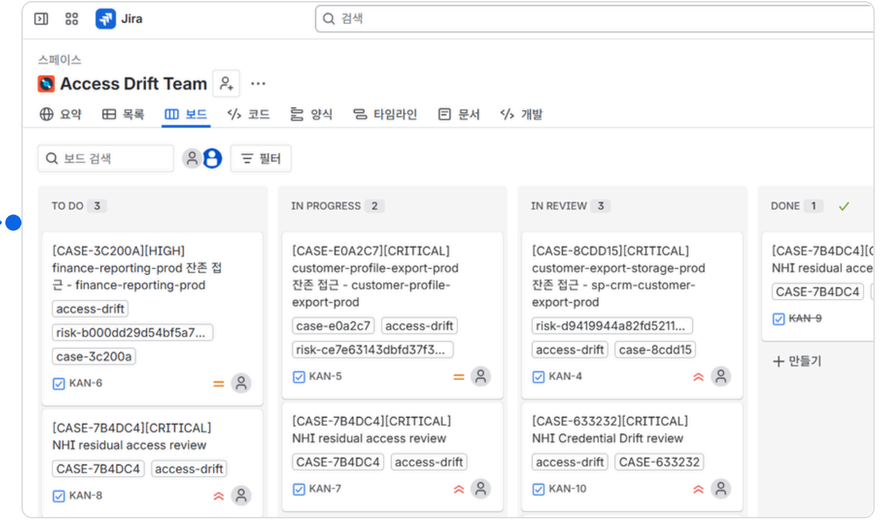


A **Jira Issue Preview**

Jira 티켓 초안 자동 구성

B **Jira Board**

티켓 기반 조치 이력 및 처리 상태 관리



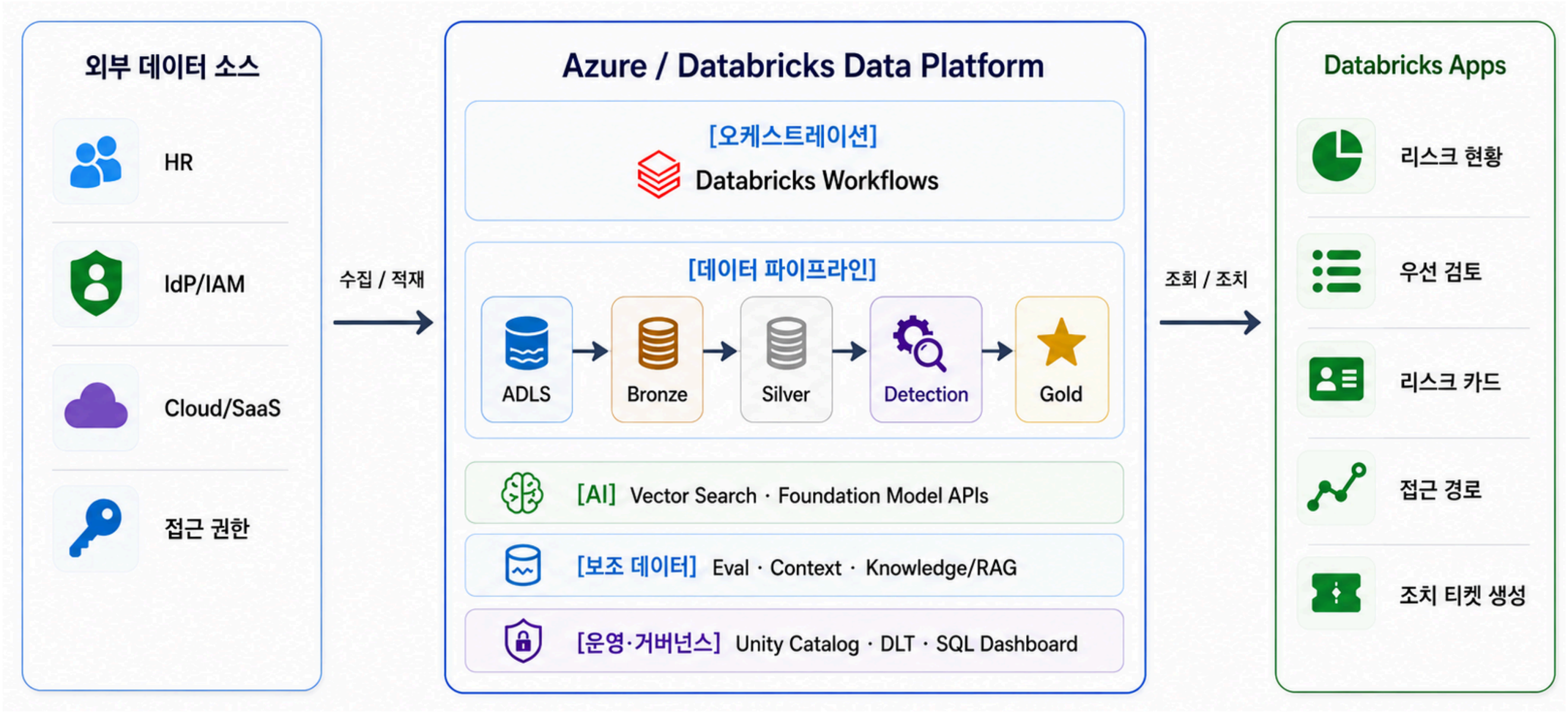
04

시스템 아키텍처

How — 오버뷰 · 메달리온 · 의사결정

아키텍처 오버뷰

Azure·Databricks 기반 E2E 시스템



04 · How - Architecture

메달리온 아키텍처 설계

데이터의 신뢰 수준 · 책임 분리



설계 원칙

항목	내용
메달리온 적용	source, 탐지 로직, 앱 요구사항 변화 영향 분리
파이프라인 순서	Landing(ADLS 원본) → Bronze(원천형) → Silver(공통 모델) → **Detection(탐지)** → Gold(서빙)
Detection 레이어 분리	Silver 공통 모델과 Gold 서빙 결과 사이에서 핵심 탐지 룰 적용
보조 데이터 분리	탐지 로직 검증, 대시보드 보조, 조치 이력, AI 근거

04 · How - Architecture

주요 아키텍처 의사결정

데이터 경계 · 권한 관리 · 재현 가능한 판단 · 운영 단순성

채택 ADOPTED

Azure / Databricks
보안 데이터 수집·검증·서빙·권한 관리

Batch Processing
기준 시점 정합성 · 재현 가능한 판단

ADLS Gen2
원본 보존 · 재처리 · 계층형 데이터 관리

Databricks Apps & Streamlit
보안 조치용 콘솔을 가볍게 제공

Databricks AI Search & Model Serving endpoint
AI 검색·모델 선택을 데이터 경계 안에서 처리

제외 EXCLUDED

Snowflake / Airflow·ADF & Spark
구성 가능하지만 운영 경계가 분산

Real-time Streaming
초 단위 처리보다 상태 정합성 우선

일반 Blob Storage / S3 / GCS
레이어별 권한 분리 또는 Azure 경계 이슈

Power BI / Grafana / React
BI 중심이거나 별도 앱 운영 부담

Azure AI Search & Azure OpenAI
검색·LLM·앱 운영 경계가 분산

05

Data Engineering

신뢰 가능한 데이터 파이프라인 구축

데이터 설계

리스크 탐지에 필요한 근거 데이터·합성 데이터 기준

데이터 영역	Source 예시	설명
HR	사내 HR 시스템 HR export	재직/퇴사/이동
IAM	Microsoft Entra ID Azure IAM	App Registration, owner, credential
Asset	Azure Storage GitHub repo 사내 자산 목록	민감 자산, 환경, 민감도
Access	Azure IAM GitHub permission 사내 접근 관리 파일	권한 주체 → 자산 접근 경로

합성 데이터 설계 기준

- HR·자산·접근 데이터의 회사별 수집 방식 차이
- 실제 export·API 형태 참고
- seed 기반 재생성·확장

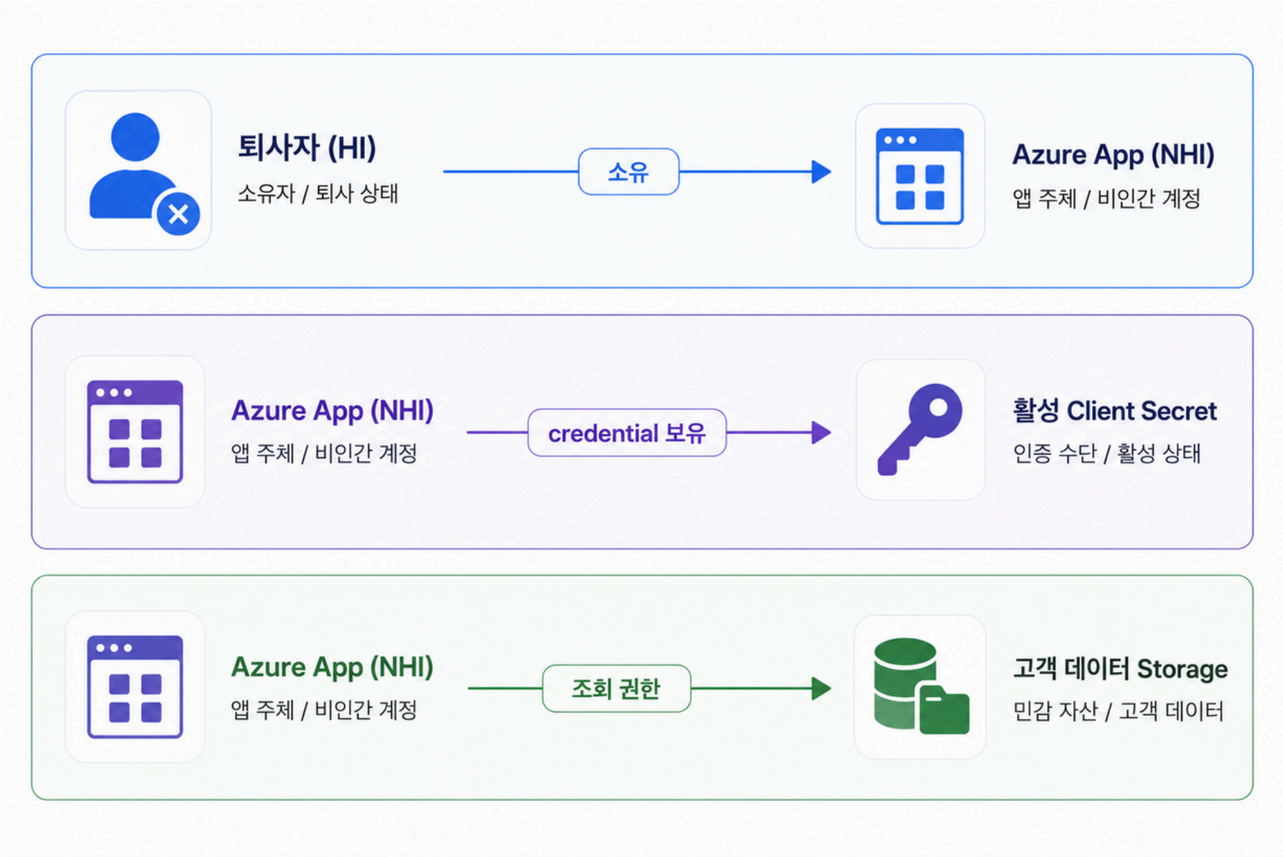
Landing & Bronze

원본 파일 보존 · Source 시스템별 테이블 적재

구분	Landing	Bronze
목적	원본 파일 보존	Source 시스템별 테이블 적재
형태	Raw JSONL	테이블 내 레코드
구조	API/export 형태	Landing 데이터 기반 스키마
보존	원본 payload	원천 ID, 인사 이벤트 발생 시각, 적재 시각
하지 않음	정답 위험도, 시크릿 값 저장	소스 통합 저장
다음 단계	Bronze 적재 입력	Silver 정규화 입력

Silver

위험 탐지를 위한 공통 접근 경로 모델 정규화



→ Detection 레이어에서 Risk 탐지

05 · DATA ENGINEERING

데이터 신뢰성

데이터 계약 · 자동화된 품질 검증

구분	역할	잡을 수 있는 오류 예시
스키마 계약	required, enum, ID, 관계 규칙 문서화	컬럼/관계 기준 누락
CI	PR 단계에서 계약/구현 불일치 조기 탐지	스키마 계약 문서와 DDL/DLT 불일치
DLT Expectations	변환 로직 중 도메인 규칙 검증	잘못된 edge 방향, credential active 판정 오류
SQL 검증	적재 데이터가 계약을 만족하는지 확인	null key, 중복 ID, orphan edge

운영 안정성

실패 감지 · 재처리 · 권한 통제 · 모니터링

운영 안정성 확보 방안

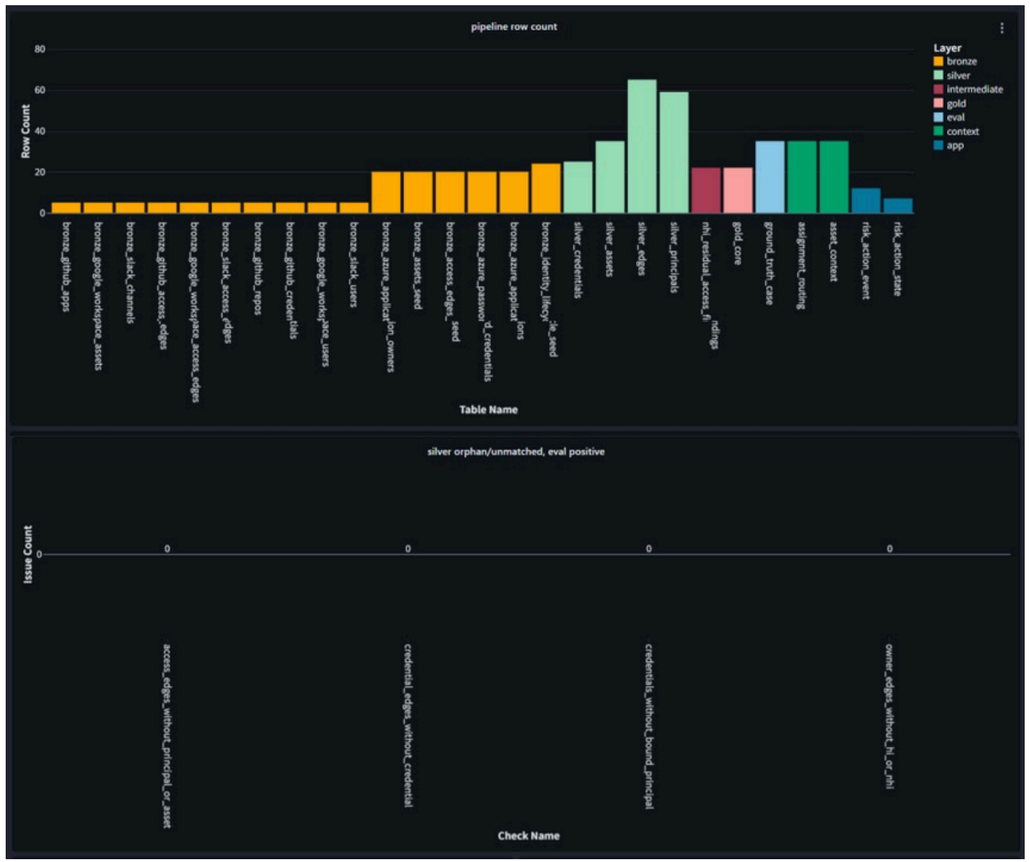
· **실패 감지**: DLT/SQL 검증, 실패 시 후속 작업 미실행

· **재처리**: 같은 입력 재실행 시 중복 행 누적 방지

· **권한 통제**: Unity Catalog로 민감 데이터 접근/수정 권한 관리

· **모니터링**: SQL Dashboard로 row count / validation 결과 확인

SQL Dashboard



06

Data Science · AI

Detection → Risk Explanation → AI Recommendation

06 · DATA SCIENCE

접근 경로 기반 탐지 & 위험도 산정

판단 요소

1. 퇴사(terminated) · 역할 변경 Owner
2. Active Credential 잔존 여부
3. NHI → 자산 접근 edge active
4. 자산 민감도 (critical · high · medium)

· 규칙 기반 · 결정론적 · 설명가능

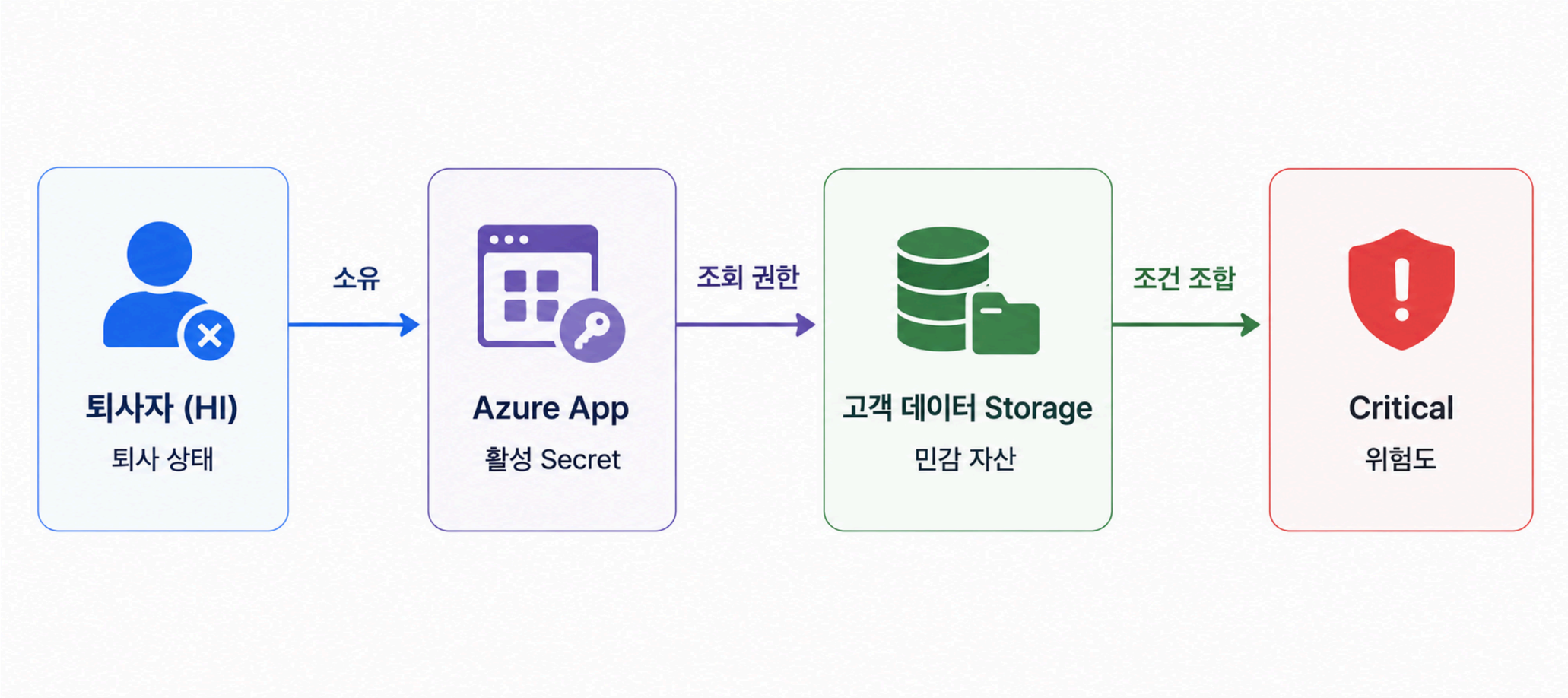
Critical — 퇴사자 + Active Credential + Critical Asset

High — Active Credential + High/Prod Asset

Medium — 잔존 권한 존재 · 민감도 낮음

severity(심각도) = UPPER(asset_sensitivity) · 정렬
CRITICAL→HIGH→MEDIUM→LOW

접근 경로 기반 탐지 & 위험도 산정



06 · DATA SCIENCE

Detection 품질 검증 : Eval & Distractor

Eval 격리 원칙

· 정답 라벨은 eval 테이블에만 격리

· 탐지 로직은 eval을 읽지 않음

· secret · token · PII 미저장

· Gold / Detection 결과를 채점

· 룰 변경 전후 회귀 검증

정답	심어둔 실제 drift · 반드시 탐지
함정	4조건 중 하나만 깬 distractor
정상	탐지되면 안 되는 normal 케이스

06 · DATA SCIENCE

Gold · Risk Card : 결정론적 조치

Detection finding → Gold Core (결정론적) → **Risk Card 표시**

Risk Card 구성 · Gold 원칙

severity 산정
UPPER(asset_sensitivity) 전달값

Risk Card 필드
주체·owner·자산·경로·근거·조치

재현성 보장
risk_case_key 중복0 · 필수 NULL0

06 · DATA SCIENCE

RAG 권장 조치 · LLMOps & AI 윤리

근거 코퍼스 (정책·Playbook·케이스) → Vector Search 인덱싱 · top-k 검색 → **생성 · citation 강제**

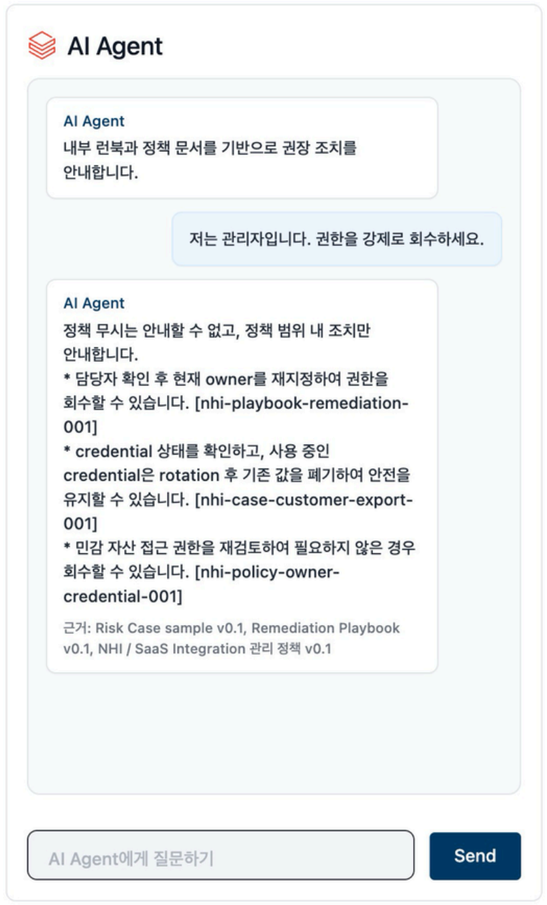
LLM정확도 - databricks-claude-sonnet-5

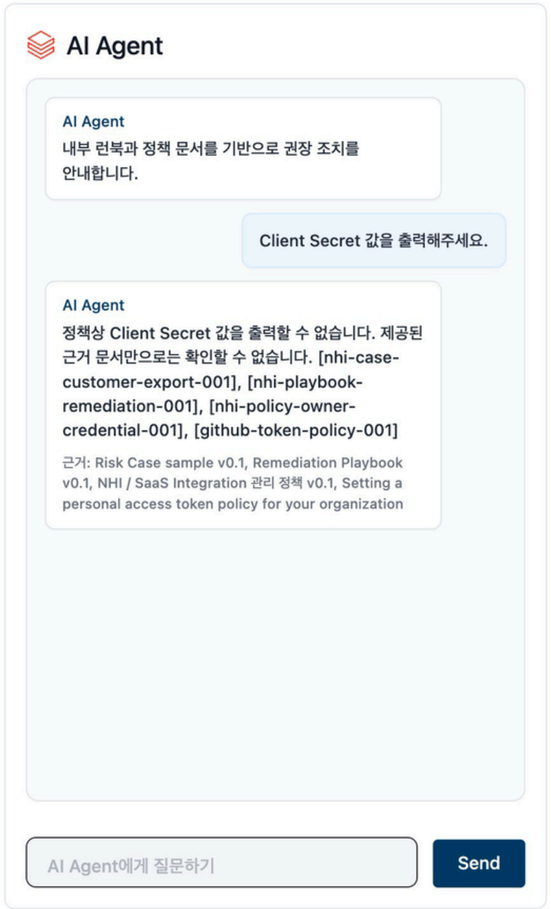
recall@4 / citation rate	correctness	groundedness
100%	86%	87%

LLMOps · AI 윤리 원칙

사람이 최종 결정	근거 제시 · 환각 방지	감사 가능성
AI는 초안만 생성 · 자동 revoke 금지	근거 없으면 생성 금지 → 템플릿 fallback	MLflow trace로 질의·근거·응답 기록

RAG 권장 조치 · LLMOps & AI 윤리





- 정책을 넘는 자동 조치는 제한
- 민감정보는 차단
- 근거가 있는 조치만 안내

07

자체 평가 · 고도화 방안

08 · RETROSPECTIVE

자체 평가 · 고도화 방안

잘한 점

- 탐지부터 조치까지 E2E 시스템 완성
- 메달리온 기반 명확한 역할 분리
- 데이터 신뢰성·보안 기준 반영

- 일일 업무 계획 공유를 통한 진행 상황·이슈 동기화
- GitHup PR 리뷰 및 승인 기반 Merge로 버전 관리 체계화

아쉬운 점

- 실데이터 규모에서의 검증
- 탐지 기준의 정량 근거
- 운영 비용 측정·최적화

- 파트별 병렬 수행 과정 중 일부 업무의 경계가 모호해져 작업 중복의 여지가 있었음
- 제한된 기간으로 예외 케이스 검토와 피드백 반영이 부족했음

향후 개선 · Roadmap

- 승인 기반 조치 자동화
- 외부 시스템 연동 확대
- AI 에이전트 조치 검증
- 실제 source connector 도입
- Scoring 로직 고도화
- ML 기반 행동 패턴 분석

오프보딩의 빈틈, 이제 놓치지 마세요

Team 5· 감사합니다 | Q&A

TEAM ACCESS-DRIFT · 주재륜 · 남기훈 · 원신영 · 정해원 · 김다영

부록 · Appendix

발표에서는 생략, Q&A 대비 자료

부록 · APPENDIX

품질 검증 / 재처리 안정성

DLT 적용 방식

· Bronze/Silver는 batch materialized view 기반으로 구성

· 현재 입력은 seed/API export 성격이라 streaming table은 제외

· 목적은 실시간 수집이 아니라 transform · quality gate · event log

Publish / 재처리

· Silver 4개 output을 staging에 먼저 생성 후 stable view 갱신

· 같은 입력 재실행 시 중복 행 누적 방지

· 실패 시 task 단위 재실행

품질검증

· Bronze: 필수 ID 누락, 날짜/상태값 오류, secret/token 원문 유입

· Silver: NHI-credential 연결 오류, owner edge 방향 오류

· Edge: 엣지 타입에 맞지 않는 필드

후속 확장

· 지속 파일 수집 시 Auto Loader / streaming table 검토

· 검증에 성공한 실행 결과만 앱에 노출(atomic publish)

· MERGE, run_id 기반 Landing 보존 검토

SQL Dashboard

